

SOC 2 POLICY REVIEW

Commitment & Obligation Analysis

Prepared for PolicyLift | Delve SOC 2 Template Review
February 2026

17 Policies Reviewed | 80+ Recurring Commitments Identified

Executive Summary

This document provides a comprehensive analysis of all 17 SOC 2 policy templates provided by Delve for PolicyLift. Each policy was reviewed to identify every recurring commitment, obligation, meeting requirement, review cadence, and operational burden the company would be agreeing to by signing off on these policies.

The review identified over 80 recurring commitments across the 17 policies. These range from daily operational requirements (patch scanning, antivirus updates) to annual governance activities (board reviews, risk assessments). Many of these commitments use vague language like “periodic” or “regular” without specifying exact frequencies, which creates compliance ambiguity.

The findings are organized into three tiers: **HIGH** risk items that require immediate attention or modification before sign-off, **MEDIUM** risk items that are notable but manageable with proper planning, and **LOW** risk items that represent standard compliance practices.

Master Commitment Calendar

Daily Requirements

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Info Security	Workstation patch compliance scanning	Daily	IT	HIGH	Automate via MDM; daily is aggressive for small teams. Consider weekly.
Info Security	Anti-virus auto-updates on workstations	Daily	IT	LOW	Standard — automate and confirm.

Weekly Requirements

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Info Security	Anti-virus definition updates (production)	Weekly	IT	MEDIUM	Reasonable if automated. Confirm tooling supports this.
BCDR	Automated user data backups	Weekly min	Ops	LOW	Standard cloud practice. Ensure replication to separate AZ.

Monthly Requirements

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Info Security	Vulnerability scans	Monthly	IT/Eng	HIGH	Monthly is aggressive. Consider quarterly for startup phase, monthly after Series A.
Info Security	IT leadership patch assessment & approval	Monthly	IT Lead	MEDIUM	Reasonable but requires formal governance meeting.

Quarterly Requirements

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Access Control	Access reviews of high-risk/critical systems	Quarterly	Managers	HIGH	Quarterly is standard for SOC 2 but labor-intensive. Ensure scope is clearly defined.
IT Leadership	IT Leadership Committee meetings	Quarterly	IT Committee	MEDIUM	Reasonable. Keep agendas tight and well-structured.
Vendor Mgmt	Risk assessment of critical non-SOC 2 vendors	Quarterly	Mgmt	HIGH	Very burdensome if many vendors lack SOC 2. Define "critical" narrowly.

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
CISO Policy	CISO reports to CEO/Board on security posture	Quarterly	CISO	MEDIUM	Reasonable if CISO role exists. Clarify report format.

Semi-Annual Requirements

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Risk Governance	Risk & Governance Committee meetings (min 2/yr)	Semi-annual	RGEC	MEDIUM	Reasonable. Combine with board meeting cycle if possible.

Annual Requirements

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Multiple	Security policy review & update	Annual	Mgmt	MEDIUM	Standard. Batch all policy reviews into one annual cycle.
Personnel	Employee performance evaluations	Annual	Supervisors	MEDIUM	Standard HR practice.
Personnel	Security awareness training (all employees)	Annual	HR/Security	MEDIUM	Standard. Use an automated training platform.
Personnel	Code of conduct reaffirmation	Annual	All staff	LOW	Standard. Can be combined with security training.
Personnel	Security policy acknowledgment	Annual	All staff	LOW	Combine with code of conduct sign-off.
Risk Assessment	Formal risk assessment	Annual	CISO/Mgmt	MEDIUM	Standard for SOC 2. Budget 2–4 weeks of effort.
Risk Assessment	Insurance needs review (incl. cyber)	Annual	Mgmt	LOW	Standard. Align with insurance renewal cycle.
Risk Assessment	Vulnerability scans (network layer)	Annual	Security	LOW	Info Security Policy says monthly. Clarify which applies.
Board Charter	Board meeting: governance, strategy, risk, budgets, succession	Annual	Board	HIGH	Extremely broad agenda. Break into focused sessions.
Board Charter	Evaluate succession plans	Annual	Board	MEDIUM	Hard for a small startup. Simplify.
Baseline Hardening	Admin access review (incl. production)	Annual	Mgmt	MEDIUM	Overlaps with quarterly access reviews — consolidate.
Baseline Hardening	Baseline configuration & policy review	Annual	Infra/Sec	LOW	Align with annual policy review cycle.
BCDR	Backup restoration testing	Annual	Ops	MEDIUM	Plan for downtime or parallel infrastructure.
Data Classification	Asset inventory review & update	Annual	Mgmt	LOW	Standard. Keep inventory in a centralized tool.
Incident Response	IR policy review and update	Annual	Mgmt	LOW	Combine with other annual policy reviews.
Incident Response	IR procedure testing (tabletop/drill)	Annual	Security	MEDIUM	Tabletop exercise is sufficient for a startup.
Network Security	Firewall rule review	Annual	IT Mgmt	LOW	Quick review if rules are well-documented.
Network Security	Network diagram review	Annual	IT/Eng	LOW	Keep diagrams in version control.

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Vendor Mgmt	Risk assessments on all third parties	Annual	Mgmt	MEDIUM	Define what the assessment involves.
Vendor Mgmt	SOC 2 report review of subservice orgs	Annual	Mgmt	LOW	Request reports during renewal cycle.
Info Security	Incident response plan testing	Annual	Security	MEDIUM	Duplicate of IR Policy. Consolidate.
Risk Governance	Charter review by Board	Annual	Board	LOW	Standard governance housekeeping.
IT Leadership	Charter review by Board	Annual	Board	LOW	Standard governance housekeeping.

Continuous / Ongoing Obligations

These are always-on obligations that require infrastructure, tooling, or constant vigilance. They represent the largest sustained resource investment.

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Acceptable Use	Maintain comprehensive audit logs	Continuous	IT/Security	MEDIUM	Requires SIEM or log aggregation tool. Budget \$500–\$2K/mo.
Acceptable Use	System & network activity monitoring	Continuous	IT/Security	MEDIUM	Can overlap with logging. Use a single platform.
Info Security	Audit log collection, monitoring & alerting	Continuous	IT	HIGH	Core SOC 2 requirement. Must have tooling in place.
Info Security	System capacity & performance monitoring	Continuous	IT	MEDIUM	Standard cloud practice. Use cloud-native monitoring.
Info Security	Log retention (1 year minimum)	Continuous	IT	MEDIUM	Storage cost scales with growth. Budget accordingly.
Baseline Hardening	System monitoring (capacity, performance, alerts)	Continuous	IT	HIGH	Requires 24/7 capability. Consider managed service.
Baseline Hardening	Logging & event monitoring	Continuous	IT	HIGH	Overlaps with Info Security Policy. Consolidate.
Network Security	Network traffic monitoring for intrusions	Continuous	IT/Eng	HIGH	Requires IDS/IPS or managed SOC service.
Network Security	Centralized logging for all network devices	Continuous	IT/Eng	MEDIUM	Standard. Use cloud-based log aggregation.
Change Mgmt	Formal change control for all changes	Per change	All teams	HIGH	Define "standard changes" broadly to reduce bottleneck.
Change Mgmt	Production code requires additional approval	Per deploy	Approvers	MEDIUM	Standard via branch protection rules.
Change Mgmt	Customer notification for significant changes	Per change	Product	MEDIUM	Define "significant" clearly.
Access Control	Offboarding within 1 business day	Per term.	HR/Security	HIGH	Strict SLA. Automate with HRIS/IAM integration.
Incident Response	Vulnerability remediation: Critical 24–72hrs	Per vuln	IT/Eng	HIGH	Very aggressive. Consider 72hrs minimum.
Incident Response	Vulnerability remediation: High 7–14 days	Per vuln	IT/Eng	MEDIUM	Reasonable with proper triage process.

Source Policy	Commitment	Frequency	Owner	Risk	Recommendation
Incident Response	48hr preliminary investigation of incidents	Per incident	CTO	HIGH	Ensure CTO has backup/delegate.
CISO Policy	Continuous risk identification & assessment	Continuous	CISO	HIGH	Full-time CISO function. Must have dedicated person.
CISO Policy	Vendor security oversight	Continuous	CISO	MEDIUM	Overlaps with Vendor Mgmt Policy. Consolidate.

Top 15 Items Requiring Attention Before Sign-Off

These items represent the most significant operational commitments. Each should be reviewed and potentially modified before PolicyLift signs off on the policies.

#	Policy	Commitment	Frequency	Why This Matters & What to Change
1	Incident Response	Critical vulnerability remediation	24–72 hours	This is the single most aggressive SLA. A critical CVE on a Friday evening means someone works the weekend. Change to 72 hours minimum, with 24-hour target for actively exploited vulnerabilities only.
2	Incident Response	Preliminary incident investigation	Within 48 hrs	Requires CTO and Chief Architect availability within 48 hours. If either is unavailable, you are non-compliant. Add delegate/backup language.
3	Info Security	Daily workstation patch compliance scanning	Daily	Scanning every workstation daily requires endpoint management tooling and creates alert fatigue. Weekly is more practical for a startup.
4	Info Security	Monthly vulnerability scans	Monthly	Monthly scanning with mandatory remediation creates constant security sprint work. Quarterly is more common for startups.
5	Access Control	Quarterly access reviews	Quarterly	Must audit all user accounts on high-risk systems every quarter. Clearly define which systems are in scope to limit effort.
6	Vendor Mgmt	Quarterly risk assessment of non-SOC 2 vendors	Quarterly	If you have 5+ critical vendors without SOC 2, that is 20+ assessments/year. Define "critical" very narrowly.
7	Change Mgmt	Formal change control for ALL changes	Every change	If interpreted literally, even minor config tweaks need approval. Define broad "standard changes" category.
8	Access Control	1 business day offboarding SLA	Per term.	Requires disabling all accounts, revoking certs, recovering hardware in 1 day. Automate deprovisioning.
9	Change Mgmt	Critical patches "as soon as possible"	Ad hoc	No defined SLA. Define: 24hrs for actively exploited, 72hrs for critical, 7 days for high.
10	Board Charter	Annual board meeting with 15+ agenda items	Annual	Unrealistic as one meeting. Split into focused quarterly sessions.
11	Board Charter	"Regular" executive sessions with auditors	Undefined	"Regularly" is never defined. Pin to semi-annual to match RGEC schedule.
12	BCDR	BC/DR plan testing	"Periodic"	Undefined cadence. Specify annually for tabletop; full simulations every 2 years.
13	Company Handbook	Maternity 16 wks + parental up to 62 wks	Per event	Total leave could be 14+ months. Verify this matches your actual benefits and jurisdiction.
14	Network Security	Inspect all personal mobile devices	Per device	Manual inspection is unsustainable. Replace with automated MDM compliance checking.
15	CISO Policy	Full-time CISO function, 12+ responsibilities	Continuous	Assumes dedicated CISO with budget and team. If part-time, scope needs to be realistic.

Meeting & Committee Commitments Summary

Below is every meeting or committee session the policies commit PolicyLift to holding.

Meeting / Forum	Frequency	Attendees	Source Policy	Recommendation
Board of Directors Annual Meeting	Annual	Board, CEO, Management	Board Charter	Split 15-item agenda into focused quarterly sessions
Executive Sessions with Auditors	"Regularly" (undefined)	Board, Mgmt, Auditors	Board Charter	Define as semi-annual. Align with RGEC schedule.
Risk & Governance Committee	Semi-annual (min 2/yr)	RGEC Members	RGEC Charter	Reasonable. Combine with board cycle.
IT Leadership Committee	Quarterly	IT Leadership, CTO	IT Leadership Charter	Reasonable. Keep focused on security review.
Post-Implementation Reviews	"Periodic" (undefined)	Change Mgmt team	Change Mgmt	Define as monthly. Review high/medium impact only.
Emergency Change Retrospectives	"Periodic" (undefined)	Service Mgmt team	Change Mgmt	Combine with post-impl reviews.
Senior Mgmt Incident Briefings	Per security incident	CTO, Senior Mgmt	Incident Response	High/medium severity only. Low via email.
CISO Security Posture Reports	Quarterly (implied)	CISO, CEO, Board	CISO Policy	Written report at IT Leadership meeting.

Policy-by-Policy Summary

Policy	Risk Level	Summary & Key Concerns
Acceptable Use Policy	LOW-MED	Primarily user-focused with limited company obligations. Main commitments: maintain audit logs (continuous), system monitoring (continuous), software approval process (per request). No explicit training schedule — clarify if annual training is intended.
Access Control & Termination	MED-HIGH	Key commitments: quarterly access reviews of high-risk systems (significant effort), 1 business day offboarding SLA (strict), onboarding documentation per hire. Clearly define which systems are in scope.
Baseline Hardening Policy	MEDIUM	Annual access review, annual risk assessment, continuous system monitoring, vulnerability scanning, backup testing. Most items overlap with other policies. Consolidate monitoring requirements.
Board of Directors Charter	HIGH	Most governance-heavy policy. Annual meeting with 15+ agenda items, undefined "regularly" sessions with auditors, ongoing oversight of internal controls. Reads as if written for a mid-to-large company. Simplify.
Business Continuity & DR	MED-HIGH	Requires BCP and DRP for all "critical" departments (undefined scope), periodic testing (undefined frequency), annual backup restoration testing. Almost every frequency is vague. Pin down before signing.
Change Management Policy	HIGH	Most operationally impactful policy. Formal approval for all changes, separate dev/test environments, customer notification, undefined critical patch SLA. Directly affects engineering velocity.
CISO Policy	HIGH	Assigns 12+ continuous responsibilities to the CISO role. If this is a part-time function, the scope is unrealistic. Risk management, vendor oversight, incident response, training, budget management — all continuous.
Company Handbook	MEDIUM	Standard employment handbook. Notable: 16-week maternity + 62-week parental leave (very generous), unlimited paid jury duty, extensive monitoring rights. Verify leave policies match actual benefits.
Data Classification Policy	LOW-MED	Relatively lightweight. Annual asset inventory review, ongoing asset classification. Default classification of "Confidential" for unclassified data could cause over-restriction.
Incident Response Policy	HIGH	Most aggressive SLAs: critical vulnerabilities 24-72 hours, 48-hour preliminary investigation window, automated scanning (continuous). Loosen critical vuln SLA to 72-hour minimum.
Information Security Policy	HIGH	Broadest policy with 43+ commitments. Daily patch scanning, weekly AV updates, monthly vulnerability scans, continuous monitoring/logging. This single policy generates the most operational work.
IT Leadership Committee Charter	LOW-MED	Quarterly committee meetings, meeting minutes, action item tracking, annual charter review. Reasonable governance overhead.
Network Security Policy	MED-HIGH	Continuous network monitoring, centralized logging, annual firewall reviews, penetration testing (undefined frequency), personal device inspection. Device inspection is impractical without MDM.

Policy	Risk Level	Summary & Key Concerns
Personnel Security Policy	MEDIUM	Annual performance evaluations, annual security training, annual acknowledgments, background checks per hire, training records maintenance. Standard HR compliance.
Risk Assessment & Treatment	MEDIUM	Annual formal risk assessment, vulnerability scanning, insurance review, risk register. "Immediately" develop action plans for critical risks — change to "within 5 business days."
Risk & Governance Exec Committee	MEDIUM	Semi-annual meetings, ongoing risk/fraud/cybersecurity oversight, 22 total responsibilities. Broad investigation authority and unlimited consultant budget — add caps.
Vendor Management Policy	MED-HIGH	Quarterly risk assessments for critical non-SOC 2 vendors is the biggest burden. Full due diligence on every contract amendment. Define "critical vendor" narrowly.

Key Recommendations Before Sign-Off

1. Pin Down Vague Frequencies

At least 20 commitments use "periodic," "regular," or "ongoing" without defining a specific cadence. Before signing, replace every instance with a concrete frequency (weekly, monthly, quarterly, or annually). This prevents auditors from interpreting these more aggressively than intended.

2. Define Scope Boundaries

Terms like "critical systems," "significant changes," "critical vendors," and "high-risk systems" appear throughout but are never defined. Create a master definitions appendix that sets clear boundaries. This is the single biggest lever for controlling compliance burden.

3. Consolidate Overlapping Requirements

Multiple policies require the same activities (continuous monitoring appears in 4+ policies, annual risk assessment in 3+ policies). Create a consolidated compliance calendar that maps each unique activity to one owner and one schedule.

4. Negotiate SLA Adjustments

The incident response SLAs (24-72 hour critical vuln remediation, 48-hour investigation) and 1 business day offboarding are the most aggressive. Loosen to: 72-hour minimum for critical vulns, 48 hours for offboarding, and add delegate/backup language for investigation.

5. Automate What You Can

Daily patch scanning, weekly AV updates, continuous monitoring, and centralized logging all require tooling. Budget approximately \$2,000–5,000/month for a security tooling stack (SIEM, vulnerability scanner, endpoint management, MDM). Without automation, these require dedicated headcount.

6. Right-Size Governance for Your Stage

The Board Charter, RGEC Charter, and IT Leadership Charter collectively create 8+ formal meetings per year. For a startup, consolidate: quarterly board meetings that incorporate RGEC and IT Leadership items, plus one focused annual strategic review.

7. Clarify the CISO Role Scope

The CISO Policy assigns a full-time executive function with 12+ continuous responsibilities. If filled part-time or alongside other duties, the policy should reflect realistic scope. Add: "commensurate with the organization's size and risk profile."

8. Verify Company Handbook Benefits

The handbook includes 16-week maternity leave plus up to 62 weeks parental leave and unlimited paid jury duty. Confirm these match your actual benefits offering and jurisdiction requirements. These are template values.